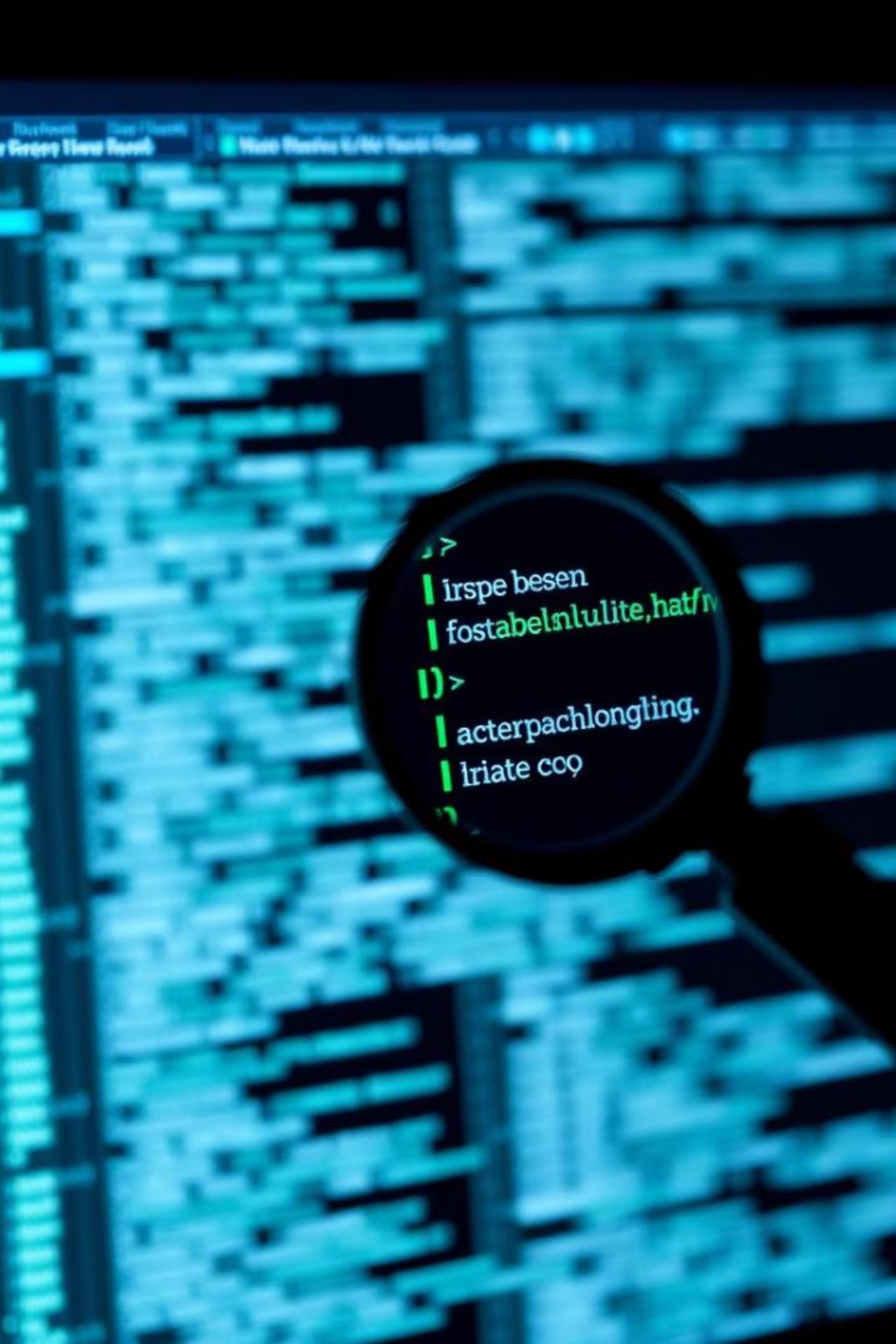




BÀI TẬP LỚN

AN TOÀN THÔNG TIN

Đề tài: Nghiên Cứu Về Các Kỹ Thuật Phân Tích Tĩnh
Trong Phân Tích Malware

Sinh viên thực hiện: A42718 Lê Thảo Quyên

PHẦN 1. TỔNG QUAN VỀ MALWARE

1 Định nghĩa

Malware là từ viết tắt của “Malicious software”, có nghĩa là phần mềm độc hại. Malware là một loại phần mềm được tạo ra và chèn vào hệ thống một cách bí mật với mục đích thâm nhập, phá hoại hệ thống hoặc lấy cắp thông tin, làm gián đoạn, tổn hại tới tính bí mật, tính toàn vẹn và tính sẵn sàng của máy tính nạn nhân.

2 Các loại Malware phổ biến

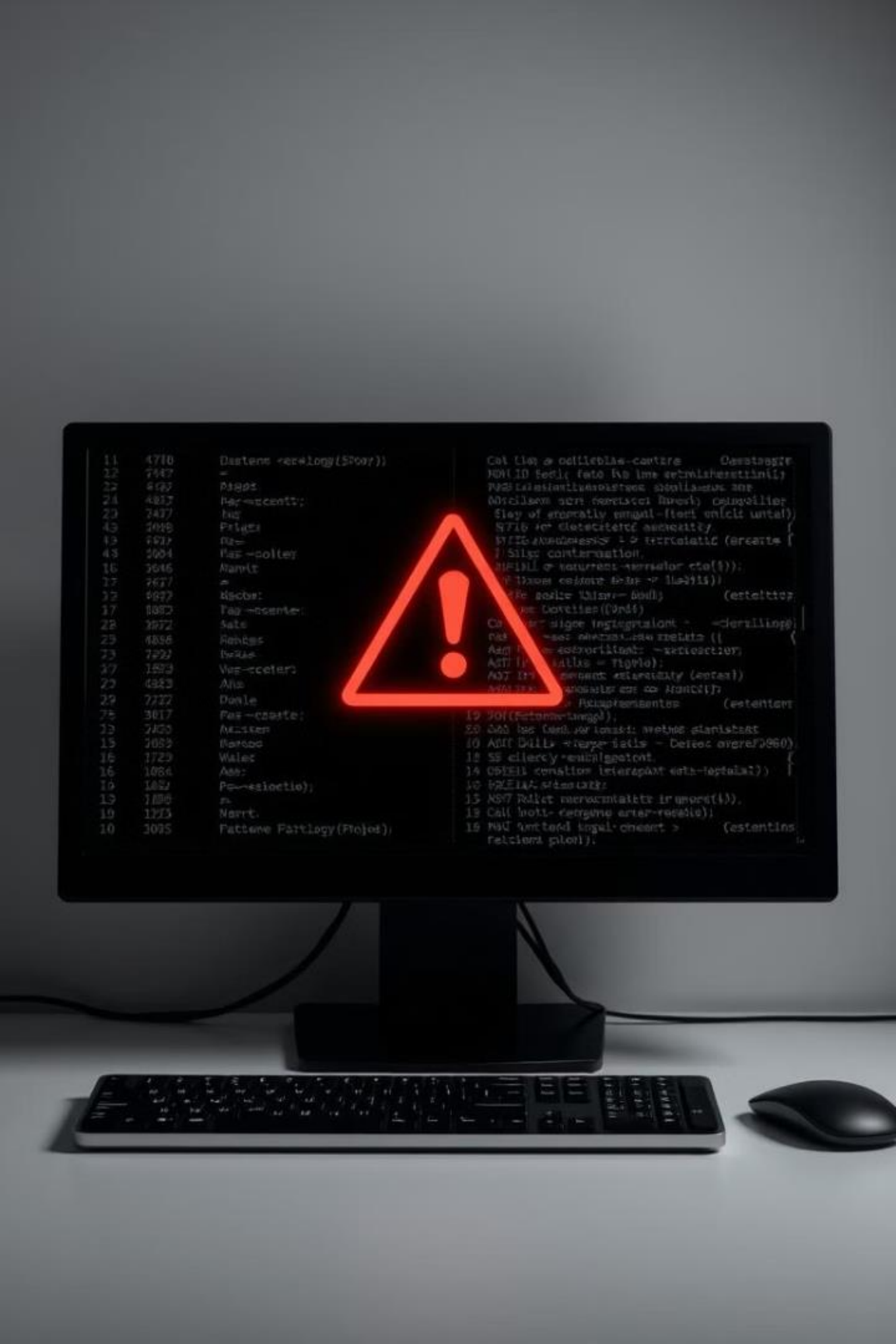
Malware bao gồm các loại phổ biến như virus, worm, trojan, spyware, keylogger, adware, rootkit và ransomware, mỗi loại có cơ chế hoạt động và tác hại riêng biệt.

3 Cơ chế hoạt động

Cơ chế hoạt động của Malware bao gồm các bước chính: lây nhiễm, ẩn mình, thực thi, điều khiển và cập nhật, và thực hiện hành vi độc hại.

4 Cách phòng tránh

Để phòng tránh Malware, người dùng cần cập nhật phần mềm và hệ điều hành, quản lý và giám sát an ninh hệ thống, sử dụng phần mềm diệt virus, sử dụng công nghệ AI và tăng cường ý thức bảo mật.



PHẦN 2. CÁC KỸ THUẬT PHÂN TÍCH TĨNH TRONG PHÂN TÍCH MALWARE

Mục tiêu phân tích

Mục tiêu phân tích Malware là xác định chính xác những gì xảy ra khi thực thi mã độc, tìm hiểu chính xác mã độc hoạt động thế nào, và ngăn chặn và tiêu diệt hoàn toàn mã độc.

Phân tích tĩnh

Phân tích tĩnh mô tả việc phân tích mã, cấu trúc của một phần mềm mà không cần thực thi chúng nhằm mục đích kiểm tra xem tập tin, phần mềm có phải mã độc hay không, và cố gắng xác định hành vi của mã độc.

Kỹ thuật phân tích tĩnh

Các kỹ thuật phân tích tĩnh bao gồm quét virus, kiểm tra mã băm, phân tích chuỗi, kiểm tra trình đóng gói, phân tích PE file Header, và dịch ngược mã máy.

Các kỹ thuật phân tích tĩnh trong phân tích Malware

1

Quét virus

Bước đầu tiên trong phân tích tĩnh là sử dụng phần mềm chống virus để quét tệp nghi ngờ. Các phần mềm này phát hiện mã độc dựa trên cơ sở dữ liệu và AI, giúp nhanh chóng xác định tệp đáng ngờ.

2

Kiểm tra mã băm

Mã băm là một giá trị duy nhất được tạo ra từ dữ liệu đầu vào, giúp xác định mã độc mà không cần tải tệp lên hệ thống trực tuyến.

3

Phân tích chuỗi

Phân tích chuỗi giúp hiểu chức năng của mã độc thông qua các chuỗi trong tệp thực thi, lưu ý rằng chuỗi có thể ở định dạng ASCII hoặc Unicode.

4

Kiểm tra trình đóng gói

Các hacker thường sử dụng kỹ thuật packed (đóng gói) và obfuscated (làm rối) để làm cho mã độc khó phân tích.

5

Phân tích PE file Header

Các file PE bắt đầu bằng một header chứa thông tin về mã nguồn, loại phần mềm, các hàm thư viện cần thiết, không gian cần thiết,... Các thông tin này là rất giá trị đối với việc phân tích mã độc.

6

Dịch ngược mã máy

Kỹ thuật dịch ngược mã máy (reverse-engineering) được thực hiện bằng cách tải lên các file thực thi, xem xét các chương trình hướng dẫn để khám phá các chương trình bên trong.

Môi trường thực hiện việc tải và phân tích mã độc

Môi trường ảo

Môi trường ảo được xây dựng tùy trường hợp, tùy từng đơn vị phân tích và người phân tích.

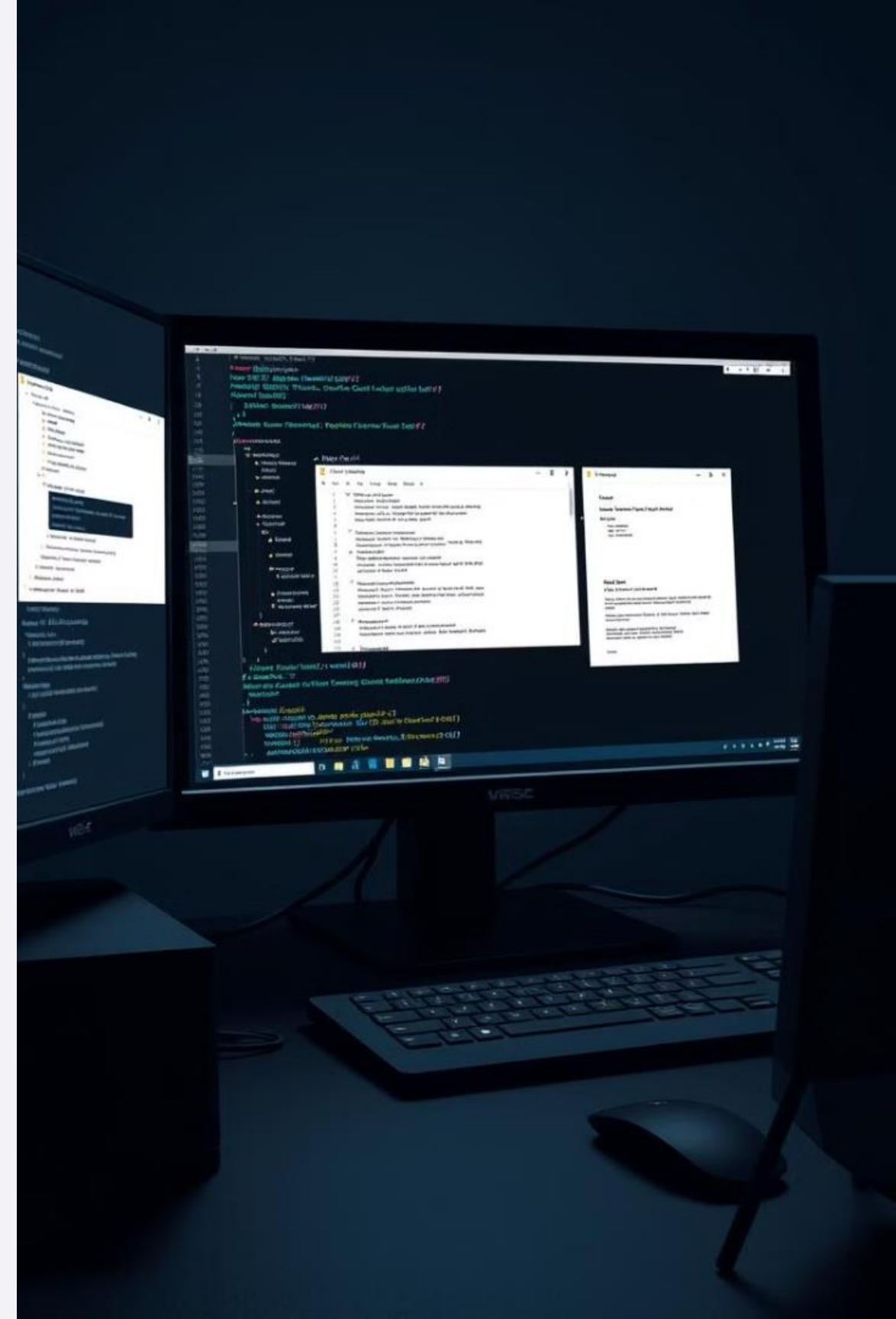
- Người phân tích không chuyên sử dụng VMware hoặc VirtualBox với Windows, Linux và một số ứng dụng thông dụng.
- Chuyên gia phân tích tạo mô hình phức tạp hơn với nhiều máy ảo trên các nền tảng khác nhau, có thể kết nối với nhau để thử nghiệm lây lan.

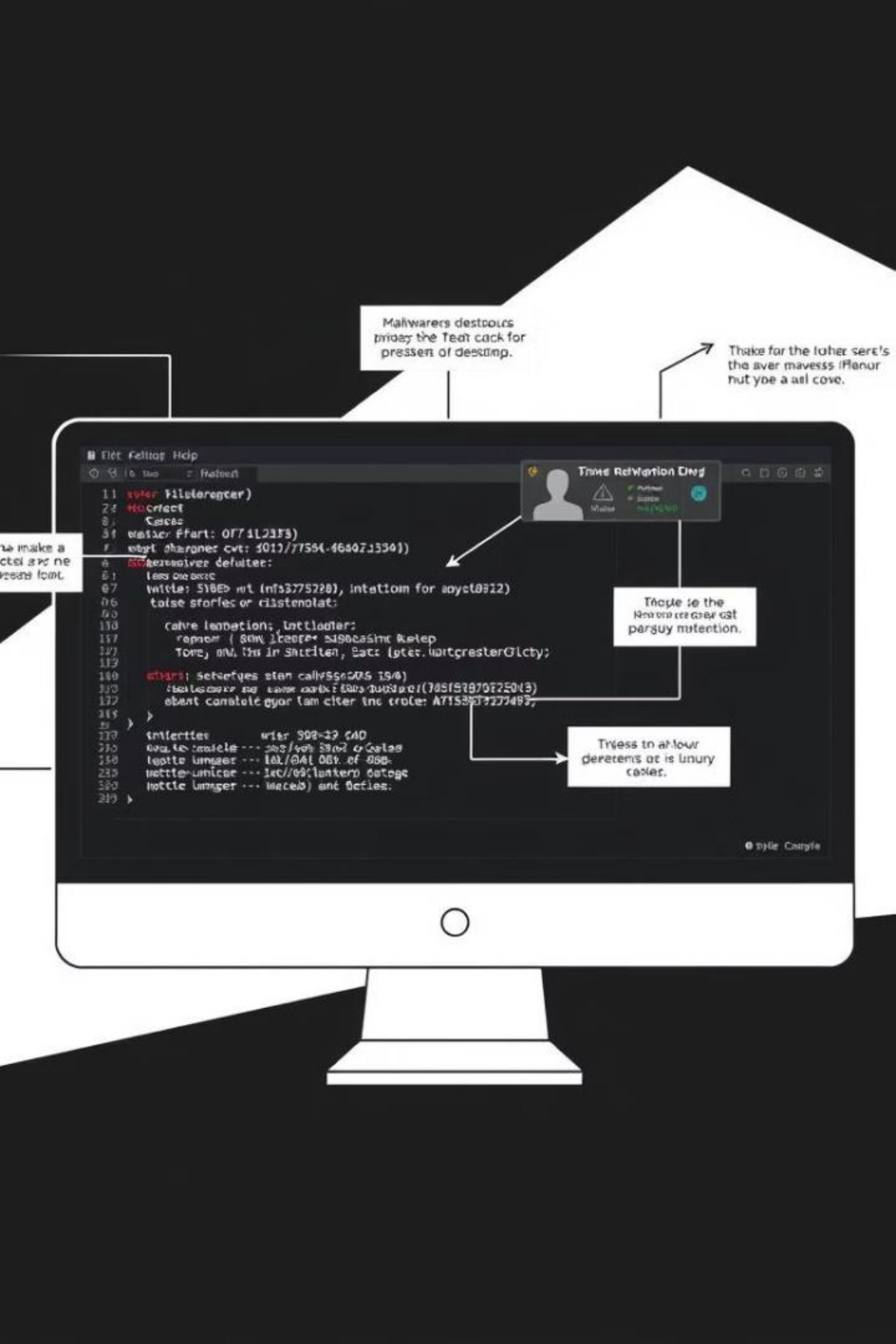
An toàn

Để phân tích mã độc người phân tích cần tạo ra những môi trường ảo để phân tích, đảm bảo mã độc không thể lây nhiễm ra ngoài hay làm hại đến máy tính của chính mình.

Quy trình

- Môi trường tách biệt khỏi mạng làm việc.
- Sử dụng công cụ riêng biệt để tải mã độc.
- Nên sử dụng môi trường khác với môi trường thực thi mã độc (VD: Linux).
- Sau khi tải về thì đổi tên, tránh trường hợp vô tình thực thi mã độc.





PHẦN 3.ỨNG DỤNG PHÂN TÍCH TĨNH TRONG PHÂN TÍCH MALWARE



Zeus Banking Trojan

Zeus Banking Trojan, còn được gọi là Zbot, là một phần mềm độc hại nổi tiếng được thiết kế để đánh cắp thông tin ngân hàng. Được phát hiện lần đầu vào năm 2007, Zeus nổi tiếng với khả năng ẩn mình và duy trì sự tồn tại, cho phép nó không bị phát hiện trong khi thu thập dữ liệu nhạy cảm như thông tin tài khoản ngân hàng và thẻ tín dụng thông qua các kỹ thuật như ghi lại phím và lấy thông tin từ biểu mẫu.



Gameover Zeus

Gameover Zeus, còn được gọi là P2PZeus hoặc GOZ, là một biến thể của Trojan Zeus, chủ yếu nhắm vào các hệ điều hành Windows. Gameover Zeus được thiết kế để đánh cắp thông tin nhạy cảm, chẳng hạn như thông tin tài khoản ngân hàng từ các máy tính bị nhiễm.



Setup

- Cài đặt VMWorkstation và Win 10.
- Vô hiệu hóa các tính năng bảo vệ thời thực, tắt Windows Defender Antivirus và vô hiệu hóa tùy chọn “Protect all network connections” đối với Domain Profile và Standard Profile.
- Cài đặt FlareVM (có sẵn các công cụ Floss và Capa, tự cài đặt thêm PeStudio và Cutter).
- Tải mã độc Zeus Banking Trojan. Ngay sau khi tải xuống, đổi lại chế độ Host-only để cắt đứt kết nối internet. Khi đã đảm bảo các quy trình an toàn, nhập mật khẩu để giải nén tệp .exe từ zip.

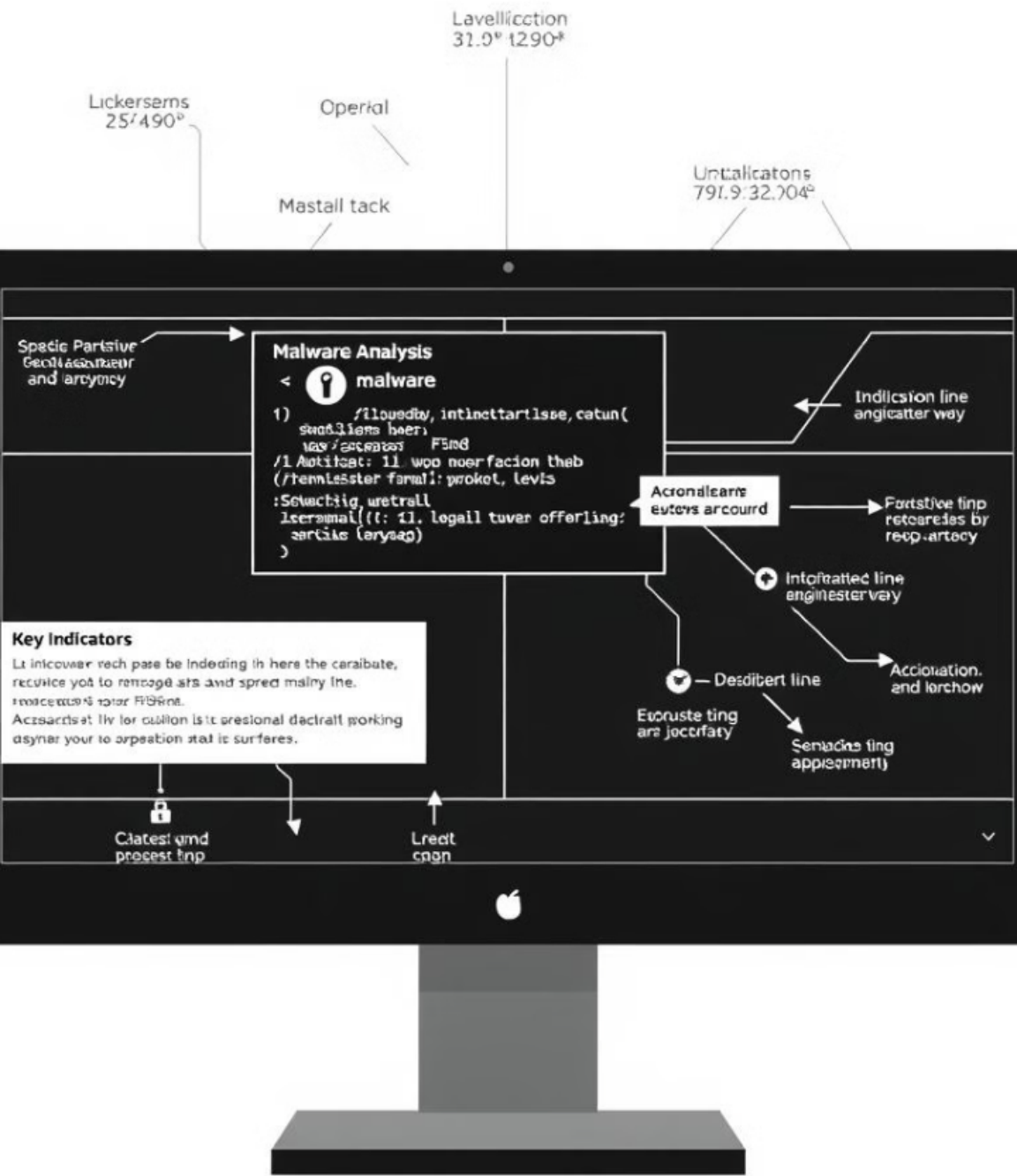


Công cụ phân tích tĩnh

Các công cụ phân tích tĩnh sẽ sử dụng trong demo bao gồm VirusTotal, PeStudio, Floss, Capa và Cutter.

Công cụ phân tích mã độc

VirusTotal	Dịch vụ trực tuyến miễn phí phân tích tệp, tên miền, địa chỉ IP và URL để phát hiện mã độc bằng cách tổng hợp dữ liệu từ nhiều sản phẩm diệt virus.
PeStudio	Công cụ giúp kiểm tra các tệp thực thi mà không cần chạy chúng, làm nổi bật lỗ hổng bảo mật, các phần đáng ngờ và siêu dữ liệu (hashes, header, properties).
Floss	Tiện ích tự động giải mã chuỗi từ mã nhị phân, giúp xác định máy chủ C2 ẩn và cấu hình mã độc.
Capa	Công cụ phát hiện hành vi trong tệp thực thi, sử dụng quy tắc để phân loại hành vi theo khung MITRE ATT&CK.
Cutter	Công cụ hỗ trợ phân tích tĩnh mã độc với khả năng giải mã, đồ họa, kịch bản và gỡ lỗi.



Demo

Tiến hành demo phân tích tĩnh mã độc Zeus Banking Trojan bằng các công cụ đã giới thiệu ở slide trước.

Demo sẽ bao gồm các bước phân tích tệp .exe bằng PeStudio, VirusTotal, Floss, Capa và Cutter.



Tổng kết

1

Kết luận

Sử dụng tất cả các thông tin đã thu thập, chúng ta có thể rút ra kết luận sau: Tập invoice_2318362983713_823931342io.pdf.exe đã bị nhiều dịch vụ phát hiện phần mềm độc hại đánh dấu, xác nhận rằng nó thực sự độc hại.

2

Hoạt động độc hại

Xem xét các cuộc gọi API, chúng ta có thể nhận thấy một số cuộc gọi đáng ngờ: GetCapture, GetWindowTextLength, GetEnvironmentVariable, GetLogicalDrives, GetDriveType, WriteFile, FindFirstFile, GetClipboardOwner, GetClipboardData.

Khi điều tra các cuộc gọi API và chức năng của chúng, cùng với các cuộc gọi cụ thể được sử dụng cùng nhau, có thể chỉ ra rằng phần mềm độc hại đang cố gắng thu thập dữ liệu của người dùng khi họ thực hiện các hành động nhất định. Phần mềm độc hại cũng đang tạo ra các tệp trong hệ thống tệp. Nó có khả năng đang cố gắng thu thập dữ liệu nhạy cảm như mật khẩu, thông tin ngân hàng và bất kỳ thông tin cá nhân nào khác. Chúng ta có thể suy luận rằng có thể đang xảy ra keylogging, một phương pháp theo dõi các phím gõ trên máy tính. Ngoài ra, phần mềm độc hại cũng đang truy xuất dữ liệu máy tính, chẳng hạn như ổ đĩa.

3

Mã hóa

Xem xét các cuộc gọi chức năng khả nghi khác cùng với các thư viện mà nó đang truy cập, chúng ta có thể suy đoán rằng phần mềm độc hại đang mã hóa các cuộc gọi chức năng bằng cách tạo ra một chuỗi văn bản ngẫu nhiên, sau đó là một thư viện được truy cập. Ví dụ: BagsSpicDollBikeAzonPoopHamsPyasmap theo sau là KERNEL32.SetCurrentDirectory. Cuộc gọi chức năng khả nghi được mã hóa với BagsSpicDollBikeAzonPoopHamsPyasmap nhưng sau đó được theo sau bởi KERNEL32.SetCurrentDirectory, điều này càng củng cố giả thuyết của chúng ta về việc mã hóa đang diễn ra.

4

Phân tích cơ bản

Đáng chú ý là các thư viện SHLWAPI.dll, KERNEL32.dll, và USER32.dll đang được truy cập, càng chỉ ra hoạt động độc hại.

Trong việc sử dụng Capa, nó đã tiết lộ khả năng của phần mềm độc hại mẫu. Capa đã liên kết phần mềm độc hại với TACTIC ATT&CK: DEFENSE EVASION -> Virtualization/Sandbox Evasion, cho thấy phần mềm độc hại đang cố gắng tránh bị phân tích bởi các nhà phân tích phần mềm độc hại. Nó có thể đang cố gắng sử dụng một quy trình để tự hủy nếu phát hiện đang ở trong một máy ảo.

Capa cũng đã liên kết phần mềm độc hại với OBJECTIVE MBC: ANTI-BEHAVIORAL ANALYSIS -> Virtual Machine Detection, điều này càng cho thấy phần mềm độc hại đang cố gắng tránh phân tích hành vi bằng cách sử dụng phát hiện máy ảo.

5

Phân tích nâng cao

Sử dụng Cutter để tạo ra một đồ thị dựa trên các cuộc gọi API. Dựa vào thông tin trước đó, chúng ta có thể suy luận rằng các cuộc gọi API đang diễn ra theo chuỗi. Điều này hữu ích trong việc tiết lộ cho chúng ta cách mà phần mềm độc hại đang cố gắng truy cập dữ liệu. Nó cho thấy hành vi động của nó theo thứ tự xảy ra.

Cutter cũng tiết lộ một cuộc gọi API cụ thể: IsBadReadPtr. Hàm này xác minh rằng quy trình gọi có quyền truy cập đọc vào một vùng bộ nhớ xác định. Điều này càng cho thấy nỗ lực của phần mềm độc hại trong việc thu thập dữ liệu từ một cơ sở dữ liệu nhạy cảm.